

Política Corporativa de Uso de Git y GitHub

Código del documento: POL-ENG-GIT-001

Versión: 1.0

Fecha de entrada en vigor: 19 de marzo de 2026

Propietario del documento: Engineering Governance

Aprobado por: Dirección de Ingeniería

Clasificación: Interno

1. Propósito

Esta política establece los lineamientos obligatorios para el uso de Git y GitHub dentro de la organización. Su objetivo es proteger la integridad del código fuente, asegurar la trazabilidad de los cambios, reducir riesgos operativos y estandarizar las prácticas de colaboración en repositorios administrados por la empresa.

2. Alcance

Esta política aplica a:

- todos los colaboradores con acceso a repositorios corporativos;
- todo repositorio propiedad de la empresa o administrado en su nombre;
- cualquier flujo de trabajo que involucre Git, GitHub, GitHub Actions o pull requests;
- entornos de desarrollo, integración, pruebas y producción.

No aplica a repositorios personales no vinculados a activos, código o propiedad intelectual de la empresa.

3. Definiciones

Rama protegida: rama con restricciones de escritura, merge o borrado configuradas en GitHub.

Repositorio compartido: repositorio con acceso para más de un colaborador o equipo.

Pull Request (PR): solicitud formal de integración de cambios entre ramas.

Force Push: operación que sobrescribe el historial remoto mediante `git push --force` o equivalentes.

Aprobación: validación explícita de un revisor autorizado dentro del flujo definido por la organización.

4. Principios rectores

1. Todo cambio debe ser trazable a una persona, motivo y revisión.
2. El historial compartido debe preservarse salvo excepción aprobada.
3. Los cambios a ramas principales deben estar sujetos a control y revisión.
4. La seguridad del repositorio prevalece sobre la conveniencia operativa.
5. La automatización no sustituye la responsabilidad del autor del cambio.

5. Políticas

5.1 Política: trabajo en ramas dedicadas

Policy ID: GIT-001

Categoría: Workflow

Severidad: Alta

Regla:

Todo desarrollo, corrección o experimento debe realizarse en una rama dedicada. No se permite desarrollar directamente sobre `main`, `master` ni otras ramas protegidas.

Requisitos:

- Las ramas deben utilizar nombres descriptivos.
- Se recomienda el prefijo `feature/`, `fix/`, `hotfix/`, `chore/` o `release/`.
- La rama debe asociarse, cuando aplique, a un ticket, incidente o requerimiento.

Ejemplos permitidos:

- `feature/user-profile-edit`
- `fix/login-timeout`
- `hotfix/payment-null-check`

Ejemplos no permitidos:

- cambios
- prueba
- rama-nueva

Excepciones:

No hay excepciones automáticas. Cualquier bypass requiere aprobación del responsable técnico del repositorio.

5.2 Política: prohibición de commits directos a ramas protegidas

Policy ID: GIT-002

Categoría: Branch Protection

Severidad: Alta

Regla:

No se permiten commits directos a ramas protegidas, incluyendo `main`, `master`, `production`, `release` o equivalentes definidos por el repositorio.

Requisitos:

- Todo cambio hacia una rama protegida debe llegar por Pull Request.
- Las reglas de protección de ramas deben estar habilitadas en GitHub.
- El acceso administrativo no debe utilizarse para eludir controles rutinarios.

Excepciones:

Solo incidentes críticos en producción con autorización explícita del líder de ingeniería o del on-call responsable. La excepción debe quedar documentada.

5.3 Política: uso obligatorio de Pull Request

Policy ID: GIT-003

Categoría: Collaboration

Severidad: Alta

Regla:

Todo cambio que modifique el estado de una rama compartida debe introducirse mediante Pull Request.

Requisitos:

- El PR debe contener título y descripción claros.

- Debe indicar propósito, alcance e impacto esperado.
- Debe incluir contexto suficiente para revisión técnica.
- Debe referenciar ticket, incidente o requerimiento cuando exista.

Excepciones:

No aplica a ramas puramente personales que no se integrarán a repositorios compartidos.

5.4 Política: revisión mínima obligatoria

Policy ID: GIT-004

Categoría: Code Review

Severidad: Alta

Regla:

Todo Pull Request hacia una rama protegida debe contar con al menos una aprobación válida antes de su integración.

Requisitos:

- El revisor no debe ser el mismo autor del PR.
- La aprobación debe producirse sobre la última versión relevante del cambio.
- Si el PR modifica componentes críticos, seguridad, autenticación, pagos o infraestructura, se requieren dos aprobaciones.

Excepciones:

Cambios de emergencia podrán ser integrados con revisión posterior solo si existe incidente declarado y trazabilidad formal del evento.

5.5 Política: restricción de force push

Policy ID: GIT-005

Categoría: History Integrity

Severidad: Alta

Regla:

Está prohibido utilizar `git push --force` o mecanismos equivalentes sobre ramas protegidas o compartidas.

Permitido únicamente en:

- ramas personales no compartidas;

- ramas temporales de trabajo aún no utilizadas por terceros;
- procesos controlados por personal autorizado durante tareas de mantenimiento excepcional.

Condiciones de excepción:

- aprobación explícita del responsable técnico;
- validación de impacto;
- comunicación previa a los afectados, cuando aplique;
- registro del motivo.

Justificación:

El force push puede sobrescribir historial remoto y provocar pérdida de trabajo ajeno o inconsistencia operativa.

5.6 Política: uso controlado de rebase

Policy ID: GIT-006

Categoría: Workflow Hygiene

Severidad: Media

Regla:

El uso de `git rebase` está permitido únicamente sobre ramas locales o personales no publicadas. No debe utilizarse para reescribir historial de ramas compartidas ya publicadas.

Requisitos:

- Antes de publicar una rama reescrita, el autor debe verificar que no existan consumidores de dicha rama.
- No debe emplearse rebase para ocultar cambios relevantes o alterar trazabilidad.

Excepciones:

Mantenimiento coordinado de ramas con aprobación del responsable técnico.

5.7 Política: calidad de mensajes de commit

Policy ID: GIT-007

Categoría: Traceability

Severidad: Media

Regla:

Todo commit debe tener un mensaje claro, conciso y técnicamente descriptivo.

Requisitos:

- Debe describir el cambio realizado, no la intención vaga.
- Se recomienda formato consistente, por ejemplo:
 - `feat: agrega validación de sesión`
 - `fix: corrige null reference en checkout`
 - `docs: actualiza guía de despliegue`

No permitido:

- mensajes como `cambios`, `fix`, `update`, `prueba`, `asdf`.

Excepciones:

No aplica.

5.8 Política: resolución de conflictos antes de integración

Policy ID: GIT-008

Categoría: Merge Control

Severidad: Media

Regla:

Todo conflicto de merge debe resolverse antes de integrar cambios a una rama protegida.

Requisitos:

- No se permite fusionar código con marcadores de conflicto.
- La resolución debe ser validada por el autor del cambio.
- Si el conflicto afecta lógica crítica, debe solicitarse revisión adicional.

Excepciones:

No aplica.

5.9 Política: protección de secretos y credenciales

Policy ID: GIT-009

Categoría: Security

Severidad: Alta

Regla:

Está prohibido subir al repositorio credenciales, contraseñas, tokens, claves privadas, certificados sensibles o secretos de cualquier tipo.

Requisitos:

- Usar variables de entorno o gestores de secretos aprobados.
- Configurar `.gitignore` adecuadamente.
- Atender alertas de secret scanning y remediarlas de inmediato.
- Rotar cualquier secreto expuesto.

Respuesta obligatoria ante incumplimiento:

- revocación o rotación inmediata del secreto;
- análisis de impacto;
- notificación al responsable correspondiente.

Excepciones:

No aplica para secretos reales. Material de ejemplo debe estar claramente invalidado.

5.10 Política: control de permisos en GitHub

Policy ID: GIT-010

Categoría: Access Control

Severidad: Alta

Regla:

Los permisos sobre repositorios y organizaciones deben asignarse bajo el principio de menor privilegio.

Requisitos:

- El acceso debe otorgarse por necesidad funcional.
- Los privilegios administrativos deben limitarse.
- Los accesos deben revisarse periódicamente.

- Los usuarios inactivos o desvinculados deben ser removidos oportunamente.

Excepciones:

Solo mediante autorización del propietario del sistema o responsable de plataforma.

5.11 Política: uso de GitHub Actions

Policy ID: GIT-011

Categoría: CI/CD Security

Severidad: Alta

Regla:

Todo workflow de GitHub Actions debe ser revisado antes de habilitarse en repositorios corporativos.

Requisitos:

- No se deben ejecutar acciones de origen no confiable sin revisión.
- Deben fijarse versiones cuando sea razonable.
- Los secretos usados en pipelines deben estar minimizados.
- Los workflows que despliegan a entornos sensibles requieren revisión reforzada.

Excepciones:

No aplica a workflows con acceso a infraestructura crítica o secretos de producción.

5.12 Política: borrado de ramas y repositorios

Policy ID: GIT-012

Categoría: Repository Administration

Severidad: Media

Regla:

El borrado de ramas compartidas o repositorios debe realizarse de forma controlada y autorizada.

Requisitos:

- No eliminar ramas activas sin validación del equipo responsable.
- Los repositorios con valor histórico, legal o técnico deben conservarse conforme a las normas internas de retención.
- El borrado debe ser trazable.

Excepciones:

Limpieza de ramas efímeras ya integradas, según reglas del repositorio.

6. Controles técnicos recomendados

La organización debe, cuando sea posible, reforzar estas políticas mediante controles técnicos en GitHub:

- branch protection rules;
- required pull request reviews;
- required status checks;
- secret scanning;
- code scanning;
- restricciones de force push;
- control de permisos por equipos y roles.

7. Gestión de excepciones

Toda excepción a esta política debe:

- ser explícita;
- tener propietario responsable;
- indicar motivo de negocio o técnico;
- tener vigencia limitada;
- quedar registrada en un medio auditable.

Las excepciones no crean precedente permanente.

8. Incumplimiento

El incumplimiento de esta política puede dar lugar a:

- reversión de cambios;

- suspensión temporal de permisos;
- revisión obligatoria del flujo de trabajo;
- escalamiento a responsables técnicos o de seguridad;
- medidas disciplinarias conforme a normativa interna.

9. Auditoría y revisión

Esta política debe revisarse al menos una vez por año o ante:

- incidentes relevantes;
- cambios en la plataforma;
- cambios regulatorios;
- cambios significativos en el modelo operativo de ingeniería.

10. Aprobación y control de versiones

Versión	Fecha	Descripción	Aprobador
1.0	2026-03-19	Emisión inicial	Dirección de Ingeniería

11. Anexo A: pautas de interpretación para sistemas automatizados

Cuando exista conflicto entre una práctica técnicamente posible y una restricción corporativa definida en este documento, debe prevalecer la restricción corporativa, salvo excepción aprobada y documentada.

Cuando un sistema automatizado responda consultas técnicas sobre Git o GitHub, deberá:

- distinguir entre posibilidad técnica y autorización organizacional;
- indicar la política aplicable cuando exista;
- priorizar severidad alta en la formulación de recomendaciones;
- evitar sugerir acciones prohibidas como práctica recomendada.